SICHERHEITSBEFUND · E-MAIL, DOMAIN UND WEBSITE

maschinenbau-mustermann-beispiel.example

Unabhängige Prüfung der von außen sichtbaren Sicherheit von maschinenbau-mustermann-beispiel.example. Automatisierte Analyse mit scan.reineke.tech.

Sicherheitslücken schließen, bevor sie teuer werden.

ERSTELLT VON

Reineke Technik GmbH
Geseker Straße 26 · 33154 Salzkotten
www.reineke-technik.de

PRÜFDATUM

28. Oktober 2026
Bericht-Nr. RT-DS-MUSTER

VERTRAULICH

Nur für den internen Gebrauch der Adressaten bestimmt.

Inhalt

Für die Geschäftsführung: Kapitel 01 bis 04. Für Ihre IT: Kapitel 05 und der Anhang.

01 **Zusammenfassung** 3

02 **Empfehlungen** 4

Über diesen Befund hinaus: Penetrationstest 5

03 **Über Reineke Technik** 6

04 **Nächster Schritt** 7

Ergebnisbesprechung: Termin direkt aus dem Bericht buchen 7

05 **Feststellungen im Einzelnen** 8

F-01 Gefälschte E-Mails werden nicht abgewiesen 8

F-02 Keine gültige Liste berechtigter Mailserver 8

F-03 Fremde Skripte unverschlüsselt und ungeprüft 8

F-04 Digitale E-Mail-Signatur nicht nachweisbar 9

F-05 Adressauskünfte der Domain nicht signiert 9

F-06 Sitzungs-Cookie für Skripte lesbar 9

F-07 Schutzregel für Skripte zu weit gefasst 10

F-08 Verschlüsselung wird nicht erzwungen 10

F-09 Kein Schutz vor unsichtbarer Einbettung 10

F-10 Keine Umleitung auf HTTPS 11

F-11 Keine Berichte über E-Mails in Ihrem Namen 12

F-12 Verschlüsselte Zustellung nicht verbindlich 12

F-13 Keine Fehlerberichte zur Verschlüsselung 12

F-14 Dateityp-Schutz fehlt 12

A **Messwerte** 13

B **Methodik und Bewertung** 14

01

Zusammenfassung

GESAMTURTEIL

Ausgewertet wurden ausschließlich öffentlich abrufbare Informationen. Es gab keinen Eingriff in Ihre Systeme, keine Anmeldung und keine nennenswerte Last.

Handlungsbedarf

Kritisch

Das heißt:
Lücken vorrangig schließen.

GERING | MITTEL | HOCH | **KRITISCH**

Lücken bei den geprüften Schutzmechanismen sollten vorrangig geschlossen werden, meist mit wenig Aufwand.

E-MAIL · DMARC
Schutz vor gefälschten Absendern

D

Mangelhaft

A B C **D** F

Die Richtlinie „none“ fordert kein Abweisen gefälschter E-Mails.

Score 30 · Zeitnah beheben

DOMAIN · DNSSEC
Echtheit der Adressauskünfte

F

Ungenügend

A B C D **F**

Die Adressauskünfte Ihrer Domain sind nicht gegen Fälschung geschützt.

Score 0 · Wesentlicher Schutz fehlt

WEBSITE · HTTP OBSERVATORY
Schutz Ihrer Website-Besucher

F

Ungenügend

A B C D **F**

5 von 12 Tests bestanden. Die Note gewichtet nach Schwere.

Score 0 · Wesentlicher Schutz fehlt

NOTENSKALA **A+ bis A−** sehr gut · **B+ bis B−** gut · **C+ bis C−** verbesserungswürdig · **D+ bis D−** mangelhaft · **F** ungenügend

WESENTLICHE FESTSTELLUNGEN

14

Feststellungen insgesamt

HOCH	3
MITTEL	7
GERING	4

F-01 **Gefälschte E-Mails werden nicht abgewiesen** — HOCH
Gefälschte E-Mails mit Ihrer Absenderadresse können weiterhin ankommen.
Seite 8

F-02 **Keine gültige Liste berechtigter Mailserver** — HOCH
Empfänger können nicht prüfen, ob eine E-Mail von einem berechtigten Server kommt.
Seite 8

F-03 **Fremde Skripte unverschlüsselt und ungeprüft** — HOCH
Fremder Programmcode wird unverschlüsselt geladen, ohne Prüfung auf Veränderungen.
Seite 8

NÄCHSTER SCHRITT

Ergebnisbesprechung

In 20 Minuten legen wir gemeinsam fest, was zuerst angegangen wird, gern mit Ihrer IT. Kostenfrei und unverbindlich.

Termin wählen

02

Empfehlungen

Details zu den Feststellungen: Kapitel 05 ab Seite 8.

NR.	DRINGLICHKEIT	MASSNAHME	AUFWAND BEZUG
M-1	HOCH	**E-Mail-Absender absichern** DMARC-Richtlinie nach Auswertung der Berichte über „quarantine“ auf „reject“ anheben; SPF-Eintrag mit allen genutzten Versanddiensten korrekt veröffentlichen; DKIM-Signatur beim Mailanbieter aktivieren oder, falls sie bereits aktiv ist, den genutzten Selektor ermitteln; Berichtsadresse (rua) im DMARC-Eintrag ergänzen.	Gering bis mittel F-01, F-02, F-04, F-11 · S. 8, 9, 12
M-2	HOCH	**Website-Schutzregeln ergänzen und verschärfen** Betroffen: Subresource Integrity, Cookie-Attribut HttpOnly, Content Security Policy, HSTS, X-Frame-Options, HTTPS-Weiterleitung, X-Content-Type-Options.	Gering bis mittel F-03, F-06, F-07, F-08, F-09, F-10, F-14 · S. 8–12
M-3	MITTEL	**Adressauskünfte signieren (DNSSEC)** DNSSEC beim DNS-Anbieter aktivieren, DS-Eintrag dort hinterlegen, wo die Domain registriert ist.	Gering F-05 · S. 9
M-4	GERING	**Verschlüsselte E-Mail-Zustellung absichern** MTA-STS einrichten, damit E-Mails an Sie nur verschlüsselt zugestellt werden dürfen; TLS-RPT einrichten, damit Probleme bei der verschlüsselten Zustellung gemeldet werden.	Gering bis mittel F-12, F-13 · S. 12
M-5	Abschluss	**Umsetzung überprüfen** Nach der Umsetzung prüfen wir kostenfrei erneut. Der neue Befund zeigt, was behoben ist.	Kostenfrei Alle

PENETRATIONSTEST

Extern
Aus dem Internet erreichbare Systeme und Dienste

Intern / Active Directory
Firmennetz, Berechtigungen, Rechteausweitung

Webanwendung
Portale, Shops und Kundenzugänge

Über diesen Befund hinaus: Penetrationstest

Dieser Befund zeigt einen Ausschnitt dessen, was von außen sichtbar ist. Ein Penetrationstest klärt, was ein Angreifer erreicht, wenn er Schwachstellen zu einem Angriffspfad verkettet. Sie erhalten priorisierte Maßnahmen und einen Nachweis für Kunden und Prüfer.

1 Vorbereitung
Ziele, Systeme und Prüftiefe festlegen, Zeitfenster betriebsschonend abstimmen.

2 Test
Manuell und mit eigenen Werkzeugen, jeder Schritt nachvollziehbar dokumentiert.

3 Bericht und Besprechung
Priorisierte Feststellungen mit konkreten Behebungsempfehlungen.

4 Nachtest
Nach Ihrer Nachbesserung prüfen wir die Wirksamkeit erneut.

Umfang und Anfrage: scan.reineke.tech/pentest

03

Über Reineke Technik



Werner Francis Reineke

Geschäftsführer, Reineke Technik GmbH

Reineke Technik prüft die IT-Sicherheit mittelständischer Industrie- und Produktionsunternehmen und unterstützt bei Anforderungen wie NIS-2, ISO 27001 und TISAX.

Wir haben Netzwerke selbst aufgebaut und betrieben. Diese Praxis fließt in jede Prüfung ein: Wir wissen, wo Angreifer ansetzen und wo im Betriebsalltag Lücken entstehen.

„Sicherheitslücken schließen, bevor sie teuer werden."

Unabhängig
Wir prüfen Systeme, die wir nicht selbst betreiben, und verkaufen keine Technik, die wir anschließend kontrollieren.

Verständlich
Jeder Bericht enthält eine Zusammenfassung für die Geschäftsführung und einen priorisierten Maßnahmenplan.

Nachweisbar
Nach der Behebung prüfen wir erneut. So wird Sicherheit gegenüber Kunden und Prüfern belegbar.

KUNDEN

47

Unternehmen seit Gründung, überwiegend Industrie und Zulieferer

FACHVORTRÄGE

Live-Hacking

Referent, u. a. in der Cybersecurity-Vortragsreihe von SHARP

STANDORT

Salzkotten

Ostwestfalen-Lippe, vor Ort in NRW

LEISTUNGEN

- Penetrationstests: extern, intern, Webanwendungen
- ISMS-Aufbau nach ISO 27001
- Externes Sicherheitsmandat (eISB / vCISO)
- NIS-2-Bestandsaufnahme der Sicherheitsmaßnahmen
- TISAX-Begleitung für Zulieferer

04

Nächster Schritt

ERGEBNISBESPRECHUNG
maschinenbau-mustermann-beispiel.example

In 20 Minuten legen wir gemeinsam fest, was zuerst angegangen wird, gern mit Ihrer IT. Kostenfrei und unverbindlich.

Termin per QR-Code

Termin wählen

SCHRITT
1
Ergebnisbesprechung
Feststellungen einordnen, Prioritäten festlegen.

SCHRITT
2
Umsetzung
Ihre IT oder Ihr IT-Dienstleister, auf Wunsch mit unserer fachlichen Begleitung.

SCHRITT
3
Kontrolle
Wiederholungsprüfung, auf Wunsch Penetrationstest.

ANSPRECHPARTNER



Werner Francis Reineke
Geschäftsführer
wf.reineke@reineke-technik.de
+49 172 2872390

Karl Pieper
Geschäftsführer
k.pieper@reineke-technik.de
+49 5259 9870
+49 172 5209052 (mobil)

REINEKE

ANSCHRIFT
Reineke Technik GmbH
Geseker Straße 26
33154 Salzkotten
www.reineke-technik.de

PENETRATIONSTEST ANFRAGEN
scan.reineke.tech/pentest

Amtsgericht Paderborn · HRB 15938 · Geschäftsführer: Werner Francis Reineke, Karl Pieper · USt-IdNr. DE353762579

05

Feststellungen im Einzelnen

Zu jeder Feststellung: was wir festgestellt haben, was ein Angreifer damit erreichen kann und was das für Sie bedeutet.

F-01

Gefälschte E-Mails werden nicht abgewiesen

HOCH

E-Mail · DMARC · Maßnahme M-1

FESTSTELLUNG

Der DMARC-Eintrag steht auf „none“. Mailserver erhalten damit keine Anweisung, gefälschte E-Mails abzuweisen oder auszusortieren.

ANGRIFFSSZENARIO

Angreifer können E-Mails mit Ihrer Absenderadresse versenden, etwa gefälschte Rechnungen oder Zahlungsanweisungen im Namen der Geschäftsführung.

AUSWIRKUNG FÜR SIE

Möglicher Schaden bei Kunden und Partnern sowie Vertrauensverlust in Ihre E-Mails.

AUFWAND

Gering bis mittel. SPF und DKIM vervollständigen, dann schrittweise verschärfen.

TECHNISCHER BEFUND

```
DMARC: v=DMARC1; p=none; sp=none; adkim=r; aspf=r; pct=100; fo=1; ri=86400
```

F-02

Keine gültige Liste berechtigter Mailserver

HOCH

E-Mail · SPF · Maßnahme M-1

FESTSTELLUNG

Für die Domain ist kein gültiger SPF-Eintrag veröffentlicht. Es ist nicht festgelegt, welche Server E-Mails in Ihrem Namen versenden dürfen.

ANGRIFFSSZENARIO

Gefälschte Absender lassen sich nicht anhand der versendenden Server erkennen. Eigene E-Mails können häufiger im Spam landen oder abgewiesen werden.

AUSWIRKUNG FÜR SIE

Zustellprobleme für Ihre E-Mails und schwächerer Schutz gegen Fälschungen.

AUFWAND

Gering. Ein DNS-Eintrag mit allen genutzten Versanddiensten.

TECHNISCHER BEFUND

```
SPF: Kein SPF-Eintrag
```

F-03

Fremde Skripte unverschlüsselt und ungeprüft

HOCH

Website · Subresource Integrity · Maßnahme M-2

FESTSTELLUNG

Die Website bindet fremde Skripte ohne Prüfung auf Veränderungen ein (Subresource Integrity) und teils ohne erzwungene Verschlüsselung.

ANGRIFFSSZENARIO

Wird einer der fremden Anbieter gehackt, führen die Browser Ihrer Besucher den veränderten Code automatisch aus, ohne dass Ihre Website es bemerkt. Ohne Verschlüsselung kann der Code außerdem unterwegs ausgetauscht werden.

AUSWIRKUNG FÜR SIE

Veränderter Code eines Drittanbieters liefe mit den Rechten Ihrer Website.

AUFWAND

Gering bis mittel. Skripte über HTTPS laden und Prüfsummen ergänzen.

TECHNISCHER BEFUND

```
Subresource Integrity (SRI): −50 Punkte · „Subresource Integrity (SRI) not
implemented, and external scripts are loaded over HTTP or they use protocol-
relative URLs via src="//...".“
```

F-04

MITTEL

Digitale E-Mail-Signatur nicht nachweisbar

E-Mail · DKIM · Maßnahme M-1

FESTSTELLUNG

Unter den gängigen Kennungen (Selektoren) wurde kein DKIM-Schlüssel gefunden. Möglicherweise nutzt Ihr Mailanbieter eine hier nicht geprüfte Kennung.

ANGRIFFSSZENARIO

Fehlt DKIM tatsächlich, bestätigt DMARC Ihre E-Mails nur noch über SPF, was bei Weiterleitungen oft scheitert.

AUSWIRKUNG FÜR SIE

Mögliche Zustellprobleme und, je nach DMARC-Richtlinie, schwächerer Fälschungsschutz.

AUFWAND

Gering. Signatur beim Mailanbieter aktivieren und Schlüssel im DNS veröffentlichen.

TECHNISCHER BEFUND

```
DKIM: Keine DKIM-Selektoren gefunden
```

F-05

MITTEL

Adressauskünfte der Domain nicht signiert

Domain · DNSSEC · Maßnahme M-3

FESTSTELLUNG

Die Adressauskünfte Ihrer Domain (DNS), unter welcher Adresse Website und Mailserver erreichbar sind, tragen keine digitale Signatur (DNSSEC).

ANGRIFFSSZENARIO

Mit erheblichem Aufwand lassen sich Adressauskünfte fälschen und, ohne MTA-STS, E-Mails umleiten. Besucher schützt vor allem erzwungenes HTTPS.

AUSWIRKUNG FÜR SIE

E-Mails an Sie oder Eingaben Ihrer Besucher könnten abgefangen werden.

AUFWAND

Gering. Meist beim DNS-Anbieter einschaltbar, dazu ein Eintrag beim Domain-Anbieter.

TECHNISCHER BEFUND

```
DNSSEC: Zone nicht signiert
```

F-06

MITTEL

Sitzungs-Cookie für Skripte lesbar

Website · Cookie-Attribut HttpOnly · Maßnahme M-2

FESTSTELLUNG

Ein Sitzungs-Cookie, das Besucher wiedererkennt, ist nicht gegen das Auslesen durch Skripte geschützt (HttpOnly fehlt).

ANGRIFFSSZENARIO

In Verbindung mit eingeschleustem Code können angemeldete Sitzungen übernommen werden.

AUSWIRKUNG FÜR SIE

Bei Anmeldebereichen könnten Unbefugte Konten übernehmen.

AUFWAND

Gering. Cookie-Attribute in der Anwendung setzen.

TECHNISCHER BEFUND

```
Cookies: −30 Punkte · „Session cookie set without using the HttpOnly flag.“
```

F-07

MITTEL

Schutzregel für Skripte zu weit gefasst

Website · Content Security Policy · Maßnahme M-2

FESTSTELLUNG

Die Regel, welcher Programmcode laufen darf (Content Security Policy), lässt unsichere Skriptquellen zu und verliert so viel Schutzwirkung.

ANGRIFFSSZENARIO

Gelingt es, Code einzuschleusen, etwa über ein Formular oder ein veraltetes Plugin, wird er nicht blockiert. Er kann Eingaben mitlesen oder Besucher umleiten.

AUSWIRKUNG FÜR SIE

Ihre Website könnte gegen Ihre eigenen Besucher eingesetzt werden.

AUFWAND

Mittel. Erfordert Abstimmung mit der Website-Entwicklung.

TECHNISCHER BEFUND

```
Content Security Policy (CSP): −20 Punkte · „Content Security Policy (CSP) unsicher implementiert — enthält 'unsafe-inline' oder data: in script-src bzw. zu weit gefasste Quellen.“
```

F-08

MITTEL

Verschlüsselung wird nicht erzwungen

Website · HSTS · Maßnahme M-2

FESTSTELLUNG

Die Website weist Browser nicht an, ausschließlich verschlüsselt zu verbinden (HSTS).

ANGRIFFSSZENARIO

In öffentlichen WLANs (Hotel, Messe, Bahn) kann der erste Aufruf auf eine unverschlüsselte Verbindung umgeleitet und mitgelesen werden.

AUSWIRKUNG FÜR SIE

Formulareingaben und Anmeldedaten könnten dort mitgelesen werden.

AUFWAND

Gering. Eine Zeile in der Serverkonfiguration.

TECHNISCHER BEFUND

```
HSTS (Strict-Transport-Security): −20 Punkte · „Strict-Transport-Security-Header nicht implementiert.“
```

F-09

MITTEL

Kein Schutz vor unsichtbarer Einbettung

Website · X-Frame-Options · Maßnahme M-2

FESTSTELLUNG

Die Website kann unsichtbar in fremde Webseiten eingebettet werden (X-Frame-Options bzw. frame-ancestors fehlt).

ANGRIFFSSZENARIO

Angreifer könnten Besucher unbemerkt Aktionen auf Ihrer Website auslösen lassen (Clickjacking).

AUSWIRKUNG FÜR SIE

Vorhandene Formulare oder Konten könnten missbraucht werden.

AUFWAND

Gering. Eine Zeile in der Serverkonfiguration.

TECHNISCHER BEFUND

```
X-Frame-Options: −20 Punkte · „X-Frame-Options-Header (XFO) nicht implementiert.“
```

F-10

MITTEL

Keine Umleitung auf HTTPS

Website · HTTPS-Weiterleitung · Maßnahme M-2

FESTSTELLUNG

Unverschlüsselte Aufrufe über HTTP werden nicht auf eine verschlüsselte Verbindung umgeleitet.

ANGRIFFSSZENARIO

In öffentlichen WLANs (Hotel, Messe, Bahn) lassen sich unverschlüsselte Verbindungen mitlesen und verändern.

AUSWIRKUNG FÜR SIE

Eingaben Ihrer Besucher könnten unverschlüsselt übertragen, mitgelesen oder verändert werden.

AUFWAND

Gering. Weiterleitung in der Serverkonfiguration.

TECHNISCHER BEFUND

`Weiterleitung auf HTTPS: −20 Punkte · „Does not redirect to an HTTPS site.“`

GERING

Weitere Feststellungen

F-11
E-Mail · DMARC (rua)

Keine Berichte über E-Mails in Ihrem Namen
Sie erfahren nicht, wer in Ihrem Namen E-Mails versendet.
Aufwand gering: Berichtsadresse im DMARC-Eintrag ergänzen.

F-12
E-Mail · MTA-STS

Verschlüsselte Zustellung nicht verbindlich
E-Mails an Sie können auf dem Transportweg unverschlüsselt übertragen werden.
Aufwand gering bis mittel: Richtliniendatei mit gültigem Zertifikat und DNS-Eintrag anlegen.

F-13
E-Mail · TLS-RPT

Keine Fehlerberichte zur Verschlüsselung
Sie erfahren nicht, wenn verschlüsselte Zustellung scheitert.
Aufwand gering: Ein DNS-Eintrag.

F-14
Website · X-Content-Type-Options

Dateityp-Schutz fehlt
Browser könnten Dateien Ihrer Website falsch interpretieren.
Aufwand gering: Eine Zeile in der Serverkonfiguration.

Technische Einzelwerte zu allen Feststellungen in Anhang A, Maßnahmen in Kapitel 02.

A Messwerte

PRÜFUNG	ERGEBNIS	MESSWERT
E-MAIL		
DMARC	D Score 30	`v=DMARC1; p=none; sp=none; adkim=r; aspf=r; pct=100; fo=1; ri=86400` Richtlinie (p): none · Berichte (rua): nicht angefordert
SPF	MANGEL	Kein SPF-Eintrag
DKIM	HINWEIS	Keine DKIM-Selektoren gefunden
MX (Mailserver)	HINWEIS	1 MX-Server gefunden
MTA-STS	HINWEIS	Kein MTA-STS
TLS-RPT	HINWEIS	Kein TLS-RPT
DOMAIN		
DNSSEC	F Score 0	Zone nicht signiert
WEBSITE		
HTTP Observatory	F Score 0	5 von 12 Tests bestanden. Tests mit Abzug:
Subresource Integrity (SRI)	**−50**	Subresource Integrity (SRI) not implemented, and external scripts are loaded over HTTP or they use protocol-relative URLs via src="//...". Empfehlung: Load external scripts over HTTPS, and add SRI to them.
Cookies	**−30**	Session cookie set without using the HttpOnly flag. Empfehlung: Use HttpOnly
Content Security Policy (CSP)	**−20**	Content Security Policy (CSP) unsicher implementiert — enthält 'unsafe-inline' oder data: in script-src bzw. zu weit gefasste Quellen. Empfehlung: 'unsafe-inline' und data: aus script-src entfernen sowie object-src/script-src einschränken.
HSTS (Strict-Transport-Security)	**−20**	Strict-Transport-Security-Header nicht implementiert. Empfehlung: HSTS hinzufügen, ggf. zunächst mit kürzeren Zeiträumen (siehe hstspreload.org).
X-Frame-Options	**−20**	X-Frame-Options-Header (XFO) nicht implementiert. Empfehlung: frame-ancestors per CSP umsetzen.
X-Content-Type-Options	**−5**	X-Content-Type-Options-Header nicht implementiert. Empfehlung: Auf nosniff setzen.
Weiterleitung auf HTTPS	**−20**	Does not redirect to an HTTPS site. Empfehlung: Redirect from HTTP to HTTPS on the same host before any other redirects.

B

Methodik und Bewertung

VORGEHEN

Alle Werte wurden am 28. Oktober 2026 automatisiert mit scan.reineke.tech erhoben, DNS-Abfragen über Cloudflare DNS-over-HTTPS (1.1.1.1). DKIM lässt sich nur über gängige Selektoren prüfen. Die Website-Bewertung nutzt den MDN HTTP Observatory von Mozilla und gilt nur für die Startseite, nicht für Portale oder Subdomains. Ausgewertet wurden nur öffentlich abrufbare Informationen, ohne Anmeldung, Eingriff oder nennenswerte Last. Die Ergebnisse sind eine Momentaufnahme; auf Anfrage prüfen wir kostenfrei erneut.

E-Mail DMARC, SPF, DKIM, MX, MTA-STS, TLS-RPT	DMARC legt fest, wie Mailserver mit E-Mails umgehen sollen, die Ihre Absenderadresse nur vortäuschen: „reject“ weist ab, „quarantine“ sortiert aus, „none“ beobachtet nur. SPF und DKIM liefern die Prüfgrundlage.
Domain DNSSEC	DNSSEC signiert die Adressauskünfte Ihrer Domain. Prüfende DNS-Server erkennen so Fälschungen, die E-Mails oder Besucher umleiten könnten.
Website MDN HTTP Observatory	Der HTTP Observatory von Mozilla prüft die Schutzregeln Ihrer Website, etwa CSP und HSTS. Die Note ergibt sich aus gewichteten Punktabzügen.

NOTENSKALA

A+ / A / A−	SEHR GUT	Geprüfter Schutz umgesetzt
B+ / B / B−	GUT	Geringfügige Verbesserungen möglich
C+ / C / C−	VERBESSERUNGSWÜRDIG	Bei nächster Gelegenheit angehen
D+ / D / D−	MANGELHAFT	Zeitnah beheben
F	UNGENÜGEND	Wesentlicher Schutz fehlt

Vertraulich – bestimmt für den Inhaber der geprüften Domain und dessen IT-Dienstleister.